trane-firmware-threat-brief

Trane (Tracer building-automation controllers) — Firmware Attack Surface & Detection Brief

Scope: CVE and public-advisory (OSINT) research only — the firmware/software itself **was acquired** via VirusTotal Intelligence into the known-good baseline (*update 2026-10-27; see the behavioural-differential section where present*), though not fully rootfs-extracted. Every finding below comes from public vulnerability disclosures (NVD, CISA ICS advisories, vendor PSIRT) and product documentation. CVE IDs listed in the Confirmed table were each independently re-verified against NVD/CISA/vendor records before inclusion; candidate IDs that could not be confirmed were dropped, not guessed.

Identity

Field	Value
Census / OUI string	`Trane`
Operating company	Trane Technologies plc (brand: Trane; US legal entity Trane U.S. Inc. / Trane Inc.). The HVAC/controls business was spun out of Ingersoll-Rand and renamed Trane Technologies in 2020; residential equipment also sells under the American Standard Heating & Air Conditioning brand. OUI registrations appear as "Trane" / "Trane Inc."
OT devices (ARNG census)	38 across 4 states
Genuine OT vendor?	Yes
Purdue placement	Purdue Levels 1-2 (building-automation zone). Equipment/field controllers - Symbio 700/800, UC400/UC600 - sit at Level 1 (basic/local equipment control). Supervisory site controllers - Tracer SC/SC+/Concierge - sit at Level 2 (site supervisory, HMI web UI, BACnet master/router). Connected thermostats are Level 1-2 edge devices. Caveat: cloud/remote-service connectivity (Trane Connect) and internet-exposed Tracer web UIs effectively push these controllers to Level 3 / DMZ exposure when not isolated, which is where the 2026 pre-auth and hard-coded-credential findings bite.

Identity note. The census string "Trane" maps cleanly to the HVAC/building-automation maker Trane (Trane Technologies plc, via Trane U.S. Inc.). This is NOT an OUI artifact or a rebrand of an unrelated chip/camera OEM — Trane registers and ships its own networked controllers, so the MAC-vendor string and the physical device are the same company. Lineage note: the "Trane" brand passed Ingersoll-Rand -> Trane Technologies (2020 spin-off/rename), and is distinct from American Standard (the residential-brand sibling that shares some thermostat firmware). 38 devices across 4 US states is a very plausible building-automation footprint for a Guard real-property portfolio (armories, readiness centers, aviation facilities, data/IT rooms): a mix of Tracer supervisory controllers, UC field controllers, Symbio equipment controllers embedded in chillers/RTUs, and connected thermostats.

Product lines & OT relevance

Core building-automation / HVAC controls vendor. Trane devices are classic facility OT: supervisory building controllers (BAS/BMS head-ends), BACnet field/unit controllers, equipment controllers embedded inside chillers, rooftop units and split systems, and connected thermostats. In a Guard context these run heating/cooling, air handling and chilled-water plants, and increasingly carry cloud/remote-service connectivity (Trane Connect / remote diagnostics), which gives them an IT-to-OT bridge and an internet-facing attack path. HVAC compromise is a real mission risk where it backs data centers, armories with climate-sensitive stores, or aviation/maintenance facilities.

- Tracer SC, Tracer SC+ and Tracer Concierge - site/supervisory building-automation controllers (BAS head-ends); SC+ is BTL-listed as a BACnet Building Controller (B-BC)
- Tracer UC400 / UC600 - BACnet MS/TP unit/field controllers (VAV, air handlers, zones)
- Symbio 700 / Symbio 800 - equipment controllers embedded in chillers (Ascend ACR, Agility HDWA), IntelliPak rooftop units, and Odyssey split systems
- XL824 / XL850 / XL1050 and Pivot - connected/smart thermostats (cloud auto-update, shared firmware lineage with American Standard)
- Legacy: Tracer Summit, Tracer ES / Tracer SC predecessors
- Supported fieldbus/protocols: BACnet IP, BACnet MS/TP (RS-485), Modbus TCP/RTU, LonTalk/LonWorks (ANSI/CEA-709.1)

Attack surface

- HTTP/HTTPS web management UI on Tracer SC/SC+/Concierge (HydraMain web server) - XSS on legacy Tracer SC (CVE-2021-42534); unauthenticated pre-auth DoS reachable on the main HTTP port (CVE-2026-28253); unauthenticated API routes (/evox/tis/websocketTunnelStatus, /evox/bacnet/report, /uidata/hui/NavTreeData.hui) that leak cloud config, the full BACnet device report, and floor-plan/GUI assets (CVE-2026-28254)
- Trane Diagnostic Service SSH (TCP 22) - disabled by default, but if enabled, a deterministic PAM challenge-response (custom pam_TraneAuthenitcate.so, a modified substitution cipher with hard-coded tables) allows authentication bypass to a ROOT shell (CVE-2026-28252)
- Hard-coded/global credentials: a config file holds Blowfish-encrypted credentials for Trane global/cloud servers that are identical across devices worldwide, with the Blowfish key itself hard-coded on-device; some credentials pair with the device serial number (retrievable via an unprotected API) (CVE-2026-28255 + CVE-2026-28256)
- BACnet/IP (UDP 47808) and BACnet MS/TP (RS-485) - unauthenticated by design; writeable commandable objects, device discovery (Who-Is/I-Am), and the exposed BACnet device report enable reconnaissance and manipulation of nested controllers
- Modbus TCP (TCP 502) and LonTalk/LonWorks where integrated - no native authentication
- Symbio 700/800 equipment controllers - code/command injection via improperly sanitized input (CVE-2021-38448), reachable where these controllers are networked
- Thermostats (XL824/XL850/XL1050/Pivot) - command injection via crafted USB stick, requiring physical access (CVE-2023-4212)

- Cloud/remote-service callbacks (Trane Connect / remote diagnostics) - outbound IT-to-OT bridge that can be abused for account takeover once global credentials are recovered
- Historical: internet-exposed Tracer SC web interfaces discoverable via Shodan/Censys; default/weak web credentials in older BAS deployments

Confirmed CVEs / advisories

Each row was re-verified against an authoritative record (URL given). This is the public disclosure history, not an exhaustive list.

CVE / advisory	Applies to	Summary	Source
`CVE-2026-28252`	Trane Tracer SC+ supervisory building controller - a core OT product line likely present i	Authentication bypass leading to root-level access on Tracer SC+ via a deterministic SSH challenge-response in a custom PAM module (modified substitution cipher	https://nvd.nist.gov/vuln/detail/CVE-2026-28252
`CVE-2026-28253`	Trane Tracer SC/SC+/Concierge controllers. Verified in CISA advisory ICSA-26-071-01.	Unauthenticated pre-auth denial of service: the HydraMain HTTP receiver does not cap header size, so ~2 GB of headers with no newline exhausts memory and aborts	https://nvd.nist.gov/vuln/detail/CVE-2026-28253
`CVE-2026-28254`	Trane Tracer SC/SC+/Concierge controllers - reconnaissance aid against the BAS network. Ve	Missing authorization: unauthenticated API routes (e.g. /evox/bacnet/report, /evox/tis/websocketTunnelStatus, /uidata/hui/NavTreeData.hui) expose cloud config,	https://nvd.nist.gov/vuln/detail/CVE-2026-28254
`CVE-2026-28255`	Trane Tracer SC/SC+/Concierge controllers with cloud connectivity. Verified in CISA adviso	Use of hard-coded credentials: a config file holds Blowfish-encrypted credentials for Trane global servers that are identical across devices worldwide, enabling	https://nvd.nist.gov/vuln/detail/CVE-2026-28255
`CVE-2026-28256`	Trane Tracer SC/SC+/Concierge controllers. Verified in CISA advisory ICSA-26-071-01.	Hard-coded security-relevant constants: the Blowfish key used to decrypt on-device config (and keys/passwords protecting backups and firmware updates on an on-d	https://cveawg.mitre.org/api/cve/CVE-2026-28256
`CVE-2023-4212`	Trane XL824/XL850/XL1050/Pivot thermostats - plausible among the connected edge devices in	Command injection on Trane connected thermostats via a crafted USB stick (physical access); CWE-74, CVSS v3 6.8 (AV:P). Affects XL824/XL850/XL1050 firmware <=5.	https://nvd.nist.gov/vuln/detail/CVE-2023-4212
`CVE-2021-42534`	Trane Tracer SC supervisory controller - legacy units may still be deployed in the census.	Cross-site scripting (reflected) in the Tracer SC building-automation controller web UI that could redirect a user to a malicious page; CWE-79, CVSS v3 6.3. Aff	https://nvd.nist.gov/vuln/detail/CVE-2021-42534

CVE / advisory	Applies to	Summary	Source
`CVE-2021-38448`	Trane Symbio 700/800 equipment controllers embedded in chillers/rooftop units - likely amo	Code/command injection: Symbio equipment controllers do not sanitize input containing code syntax, allowing arbitrary code to alter the controller's intended fl	https://nvd.nist.gov/vuln/detail/CVE-2021-38448

Detection guidance

- Baseline and monitor BACnet/IP on UDP 47808: alert on unexpected Who-Is/I-Am sweeps, new device instances, and WriteProperty to commandable/priority-array objects from non-engineering hosts
- Monitor BACnet MS/TP RS-485 trunks via OT network sensors where tapped; track device MAC-layer address churn on the trunk
- Watch TCP 80/443 to Tracer SC/SC+/Concierge web UIs: alert on access from outside the facilities/management VLAN, on large header/body requests (the DoS sends ~2 GB with no newline), and on hits to unauthenticated routes /evox/bacnet/report, /evox/tis/websocketTunnelStatus, /uidata/hui/NavTreeData.hui
- Alert on ANY TCP 22 (SSH) to a Tracer controller - the Trane Diagnostic Service SSH is off by default, so its presence indicates the root-shell exposure path (CVE-2026-28252)
- Monitor Modbus TCP 502 and LonTalk/LonWorks (ISO/IEC 14908-1 IP tunneling, UDP 1628/1629) where those integrations exist
- Log sources: Tracer supervisory controller syslog/audit logs, IT/OT boundary firewall logs, and NetFlow for outbound cloud callbacks to Trane Connect / Trane remote-service endpoints (unexpected new egress destinations = investigate)
- Allowlisting: restrict Tracer web UIs to named engineering-workstation IPs; deny all inbound from the internet; allowlist only the specific BACnet/Modbus peers each controller needs; egress-allowlist only required Trane cloud domains and alert on anything else
- Run external attack-surface scans (Shodan/Censys) for internet-exposed Tracer SC/SC+ web fingerprints tied to Guard netblocks
- Asset-inventory check: fingerprint firmware versions against the fixed baselines (Tracer SC+ >= v6.30.2313 / v6.3.2310, Tracer SC >= v4.4_SP7, Symbio 700 >= v1.00.0023, Symbio 800 per-model, thermostats XL >= post-5.9.8 / Pivot > 1.8)

Acquisition status

GATED - we currently hold NONE for this vendor. Trane does not publicly post controller firmware images. Firmware reaches devices through authorized Trane dealers/service technicians, the Trane technician/partner portal, and the Tracer SC+ update mechanism / Trane Connect cloud (thermostats XL/Pivot auto-update over the internet once connected). Freely available OSINT is limited to product literature - data sheets, product catalogs and install guides on elibrary.tranetechnologies.com and commercial.trane.com (e.g. BAS-PRD038x, BAS-PRC087x, Tracer install guides). To obtain actual firmware for differential/behavioral analysis we would need either a dealer-channel download (account-gated) or a physical flash/eMMC dump pulled from a device - consistent with staying advisory/OSINT-only for now. The 2026 Claroty Team82 research also documents

that backups and firmware updates are protected by keys/passwords stored on an on-device block device, further confirming firmware is not openly distributed.

Notes

High-confidence genuine OT vendor; no disambiguation problem. Strongest, most current risk is the March 2026 Tracer SC+ cluster (ICSA-26-071-01 / Claroty Team82): auth-bypass-to-root plus device-wide hard-coded credentials means a single key recovery can compromise the whole fleet's cloud identities - priority is to confirm Tracer firmware versions and network isolation across all 4 states. All 8 CVEs were verified by fetching the cited CISA advisory pages in this research; no IDs were recalled from memory. Minor version/score discrepancies exist between Claroty's blog and CISA/NVD (e.g. affected-version ceilings v5.20.1362 vs v6.2, and the CVE-2026-28255 score 6.8 vs 8.2) - CISA advisory values are used here. Acquisition remains gated: advisory/OSINT-only is the correct posture until a dealer-channel or on-device firmware pull is authorized.

Status

Item	State
Firmware/software acquired	**No** — OSINT/advisory only
Confirmed CVEs	8 (independently re-verified)
Behavioural baseline	None — no samples held
Next step	CISA/PSIRT deep pass; attempt firmware acquisition

Generated 2026-10-26 from the ot-vendor-briefs workflow (12 researchers + adversarial CVE verification). Device counts from the 2026-10-22 ARNG OT census.